

THREAT ADVISORY



VULNERABILITY REPORT

Heimdal addresses multiple vulnerabilities in v7.7.1

Date of Publication

November 18, 2022

Admiralty Code

A1

TA Number

TA2022264

Summary

First Seen: November 16, 2022

Affected Product: Heimdal: 0.5 - 7.7.0

Impact: Leading to a denial of service or remote code execution

CVE

CVE	NAME	PATCH
CVE-2022-42898	PAC parse integer overflow Vulnerability	
CVE-2022-3437	Heap-based buffer overflow in Heimdal unwrap_des3()	
CVE-2019-14870	Security misconfiguration in AD DC KDC	
CVE-2022-44640	Buffer overflow via unwrap_des3() in Heimdal GSSAPI	
CVE-2021-44758	NULL dereference DoS in SPNEGO acceptors	
CVE-2022-41916	Out-of-bounds read vulnerability in Heimdal's PKI certificate	
CVE-2021-3671	Null pointer de-reference in TGS-REQ	

Vulnerability Details

#1

Heimdal has addressed bugs in Heimdal KDC. A remote intruder can use unwrap des3() to induce a buffer overflow in Heimdal GSSAPI, leading to a denial of service or remote code execution on the host machine.

#2

CVE-2022-44640 is a critical vulnerability, that can lead to remote code execution (RCE) on a Key Distribution Center (KDC). This indicates that credentials can be compromised and can be used to hijack anyone in a realm.

#3

Heimdal's ASN.1 compiler generates code that enables specially designed DER encodings of CHOICES to activate the wrong free function. This leads to an invalid free() of an address partially or entirely within the attacker's control, finally leading to a remote code execution (RCE) vulnerability. Whereas no 0-day vulnerability reported so far.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-42898	Heimdal: 0.5 - 7.7.0	cpe:2.3:a:heimdal:heimdal:0.7.1.3:*:*:*:*:*	CWE-190
CVE-2022-3437			CWE-122
CVE-2021-44758			CWE-476
CVE-2019-14870			CWE-358
CVE-2022-44640		cpe:2.3:a:heimdal:heimdal:7.7.0:*:*:*:*:*	CWE-119
CVE-2022-41916		cpe:2.3:a:heimdal:heimdal:0.7.1.3:*:*:*:*:*	CWE-125
CVE-2021-3671			CWE-476

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.



Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>T1190</u> Exploit Public-Facing Application	<u>T1203</u> Exploitation for Client Execution	<u>T1588.006</u> Vulnerabilities
<u>T1587</u> Develop Capabilities	<u>TA0040</u> Impact	<u>T1499</u> Endpoint Denial of Service	<u>TA0002</u> Execution



Patch Details

Upgrade to Heimdal version 7.7.1



References

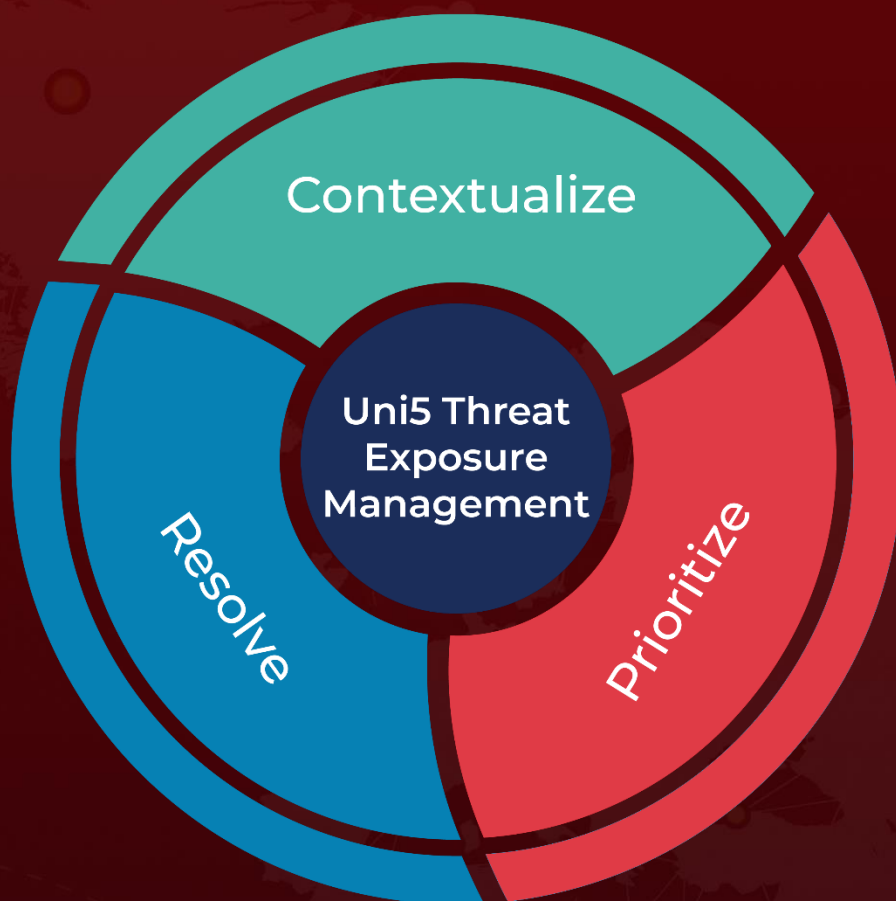
<https://github.com/heimdal/heimdal/releases/tag/heimdal-7.7.1>

<https://vigilance.fr/vulnerability/Heimdal-GSSAPI-buffer-overflow-via-unwrap-des3-39710>

What Next?

At **HivePro**, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with **Hive Pro Uni5**: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 18, 2022 • 11:30 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com